

Testing Session Management Mechanisms

A07:2021 – Identification and Authentication Failures

- Ajay M Nambiar

1. Introduction

Session management allows a web application to remember an authenticated user across multiple HTTP requests. This is usually achieved using session identifiers stored in cookies or tokens.

If session management is poorly implemented, an attacker may be able to obtain, reuse, manipulate, or predict a user's session and perform actions on their behalf.

OWASP A07:2021 identifies **session identifier exposure** and **session management flaws** as important authentication weaknesses.

2. What is Session Management?

HTTP is stateless, so applications use sessions to maintain a user's authenticated state.

A typical flow is:

User Login

↓

Authentication

↓

Session Created

↓

Session ID / Cookie

↓

Authenticated Requests

Example:

GET /account HTTP/1.1

Host: example.com

Cookie: session=abc123

The server uses the session identifier to determine which user is making the request.

3. Common Session Management Issues

Session ID Predictability

Session identifiers must be sufficiently random. Predictable identifiers may allow attackers to guess valid sessions.

Session Fixation

The application may continue using the same session identifier after authentication. If an attacker can control or obtain that identifier beforehand, they may be able to access the authenticated session.

Session ID Exposure

Session identifiers should not be unnecessarily exposed in URLs.

<https://example.com/account?session=abc123>

The A07 reference specifically identifies session identifiers exposed through URLs as a security weakness.

Improper Session Invalidation

A session should become invalid after logout. If an old session remains active, anyone possessing its identifier may continue using it.

Missing or Weak Timeouts

Sessions should expire after appropriate periods of inactivity and, where required, after a maximum lifetime.

4. Testing with Burp Suite

Burp Suite can be used to inspect and manipulate session-related requests.

Step 1 – Identify the Session Mechanism

Step 2 – Capture the Login Request

Step 3 – Test Session Reuse

Step 4 – Test Session Invalidation

Step 5 – Inspect Cookies

5. Security Impact

Successful exploitation of session-management vulnerabilities can lead to:

- Account takeover
- Unauthorized access to sensitive information
- Actions performed as another user
- Persistent access after logout
- Session hijacking
- Privilege abuse when an administrative session is compromised

The A07 reference identifies failure to invalidate sessions after logout or inactivity as a condition that can allow continued unauthorized access.

6. Secure Session Management

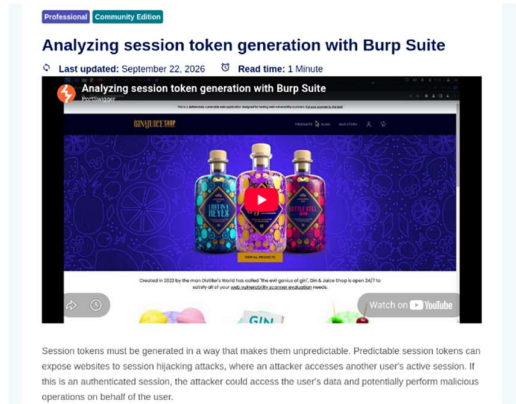
Applications should:

- Generate unpredictable, high-entropy session identifiers.
- Generate a new session ID after authentication.
- Invalidate sessions during logout.
- Implement appropriate idle and absolute timeouts.
- Avoid putting session IDs in URLs.
- Protect session cookies using appropriate attributes.
- Use HTTPS for authenticated communication.

The provided A07 material specifically recommends secure, server-side session management with high-entropy session IDs and invalidation after logout and timeouts.

7. PortSwigger Labs

Lab 1 – Analyzing Session Token Generation



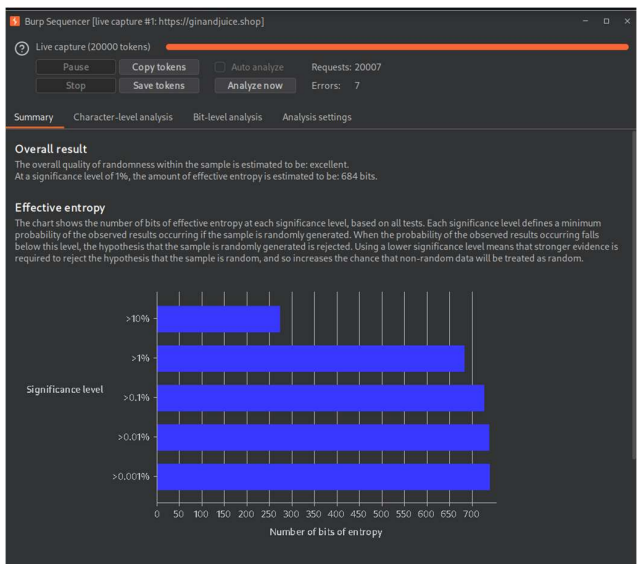
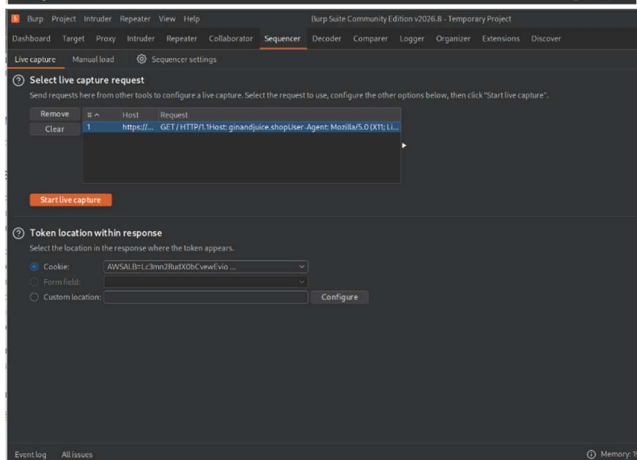
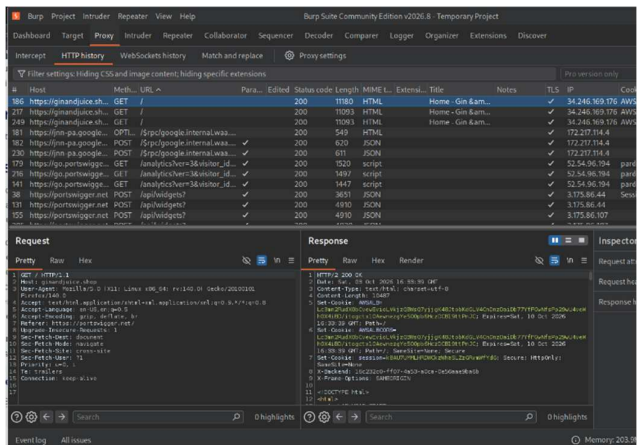
Objective:

Analyze session token randomness using Burp Suite Sequencer and identify potential predictability.

Procedure:

- Logged into the target application and obtained an authenticated session cookie.
- Located the session cookie under **Proxy → HTTP history**.
- Sent the cookie to **Sequencer**.
- Used **Start live capture** to collect multiple session tokens.
- Selected **Analyze now** and reviewed the randomness results.

Evidence:



Finding:

The Burp Sequencer analysis rated the session token randomness as excellent, with an estimated effective entropy of 684 bits. No significant predictability was identified in the analyzed sample.

Result:

The session tokens demonstrated strong randomness and did not show an apparent predictability issue.

Impact:

Predictable session tokens may allow session hijacking and unauthorized access to authenticated accounts.

Lab 2 – Decoding Opaque Data with Burp Suite

Lab: Modifying serialized data types

PRACTITIONER
LAB ✓ Solved

This lab uses a serialization-based session mechanism and is vulnerable to authentication bypass as a result. To solve the lab, edit the serialized object in the session cookie to access the `administrator` account. Then, delete the user `carlos`.

You can log in to your own account using the following credentials: `wiener:peter`

Hint

ACCESS THE LAB

Solution

Community solutions

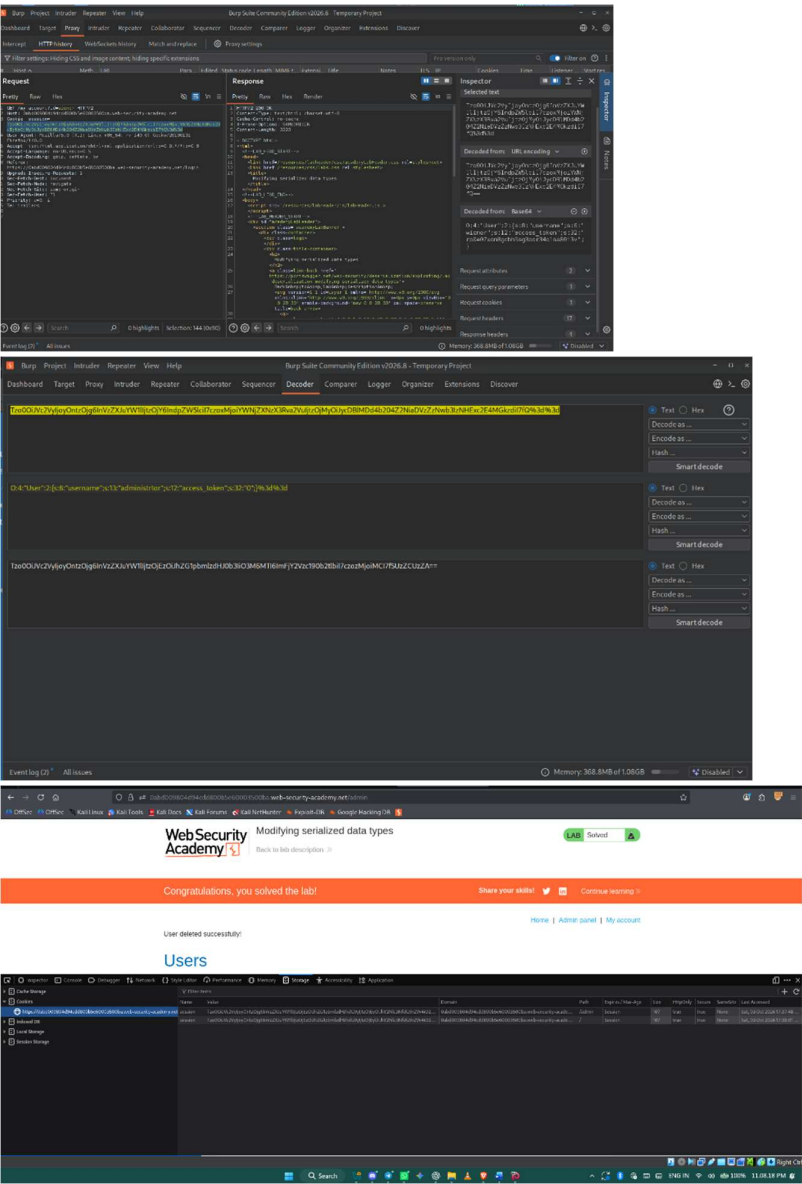
Objective:

Analyze and modify non-human-readable data using Burp Suite **Inspector** and **Decoder**.

Procedure:

- Identified opaque data in **Proxy → HTTP History**.
- Used **Inspector** to automatically decode recognized formats such as URL and Base64.
- Sent the request to **Repeater** and modified the decoded data.
- Used **Burp Decoder** to apply multiple decoding/encoding operations.
- Re-encoded the modified data and inserted it back into the request.
- Observed the application's response to determine the effect of the modification.

Evidence:



Result:

Opaque data was successfully decoded, modified, re-encoded, and tested to determine its effect on application behavior.

Impact:

Improperly protected or encoded data may expose application information or allow attackers to manipulate application behavior.

8. Conclusion

Session management is a critical part of web application authentication. A secure login mechanism alone is not sufficient if session identifiers can be predicted, exposed, reused, or remain valid after logout.

Testing session creation, rotation, reuse, expiration, and invalidation with tools such as Burp Suite helps identify weaknesses that could otherwise lead to session hijacking or unauthorized account access.

References

- [PortSwigger Web Security Academy – Testing session management mechanisms](#)
- [OWASP Top 10:2021 – A07: Identification and Authentication Failures](#)
- [OWASP Session Management Cheat Sheet](#)